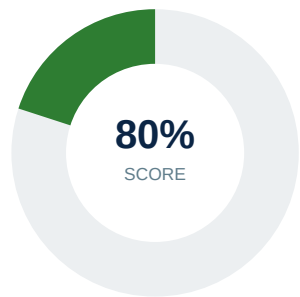


Security Audit Report

Web Application & Infrastructure Assessment



Target: <https://growlity.com/blog/brsr-principles-guide-india>
Prepared for: Client
Scan Date: 31 August 2026, 15:19
Overall Risk Status: **CRITICAL RISK**

Total Checks	Passed	Failed	Critical	High	Medium	Low
51	41	10	1	1	2	6

This report is confidential and intended solely for the addressed client. It summarizes automated findings from an external, black-box security scan and should be supplemented with manual penetration testing for a complete risk assessment.

1. Executive Summary

The assessment identified **10** issue(s) out of **51** checks performed, resulting in a security score of **80%** and an overall risk rating of **CRITICAL RISK**. There are **1 critical** and **1 high** severity finding(s) that should be prioritized for remediation.

2. SSL / TLS & Certificate Audit

Parameter	Result
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Hostname Verification	PASS
Self-Signed	NO
Valid From	Jul 18 05:50:00 2026 GMT
Valid Until	Oct 16 06:49:58 2026 GMT
Days Remaining	45
Issuer	countryName=US, organizationName=Google Trust Services, commonName=WE1
Subject	commonName=growlity.com
Subject Alt. Names (SAN)	growlity.com, *.growlity.com

3. DNS, DNSSEC & Domain Audit

Parameter	Result
A Records	104.21.65.81, 172.67.189.104
AAAA Records	2606:4700:3035::6815:4151, 2606:4700:3031::ac43:bd68
MX Records	20 mx2.zoho.com., 50 mx3.zoho.com., 10 mx.zoho.com.
NS Records	colette.ns.cloudflare.com., kolton.ns.cloudflare.com.
CAA Records	None (finding)
DNSSEC Enabled	YES
WHOIS Registrar	GoDaddy.com, LLC
Domain Expiration	2028-05-26 08:15:37+00:00
Days To Expiry	633

4. Security Issues & Recommendations

Severity	Check	Details	Recommendation
CRITICAL	Website Availability	Website returned HTTP 403.	Verify website availability and server configuration.
HIGH	HTTP to HTTPS Redirect	HTTP does not correctly redirect to HTTPS.	Configure a permanent HTTP to HTTPS redirect.
MEDIUM	X-Frame-Options	X-Frame-Options header is missing.	Configure a proper X-Frame-Options header.
MEDIUM	DNS - CAA Record	No CAA record found - any public CA can issue certs for this domain.	Add a CAA record restricting which Certificate Authorities may issue certificates.
LOW	Information Disclosure - server	Server technology information exposed: cloudflare	Remove unnecessary technology/version information from HTTP headers.
LOW	Security.txt (RFC 9116)	No security.txt file found.	Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
LOW	Cross-Origin-Opener-Policy	Cross-Origin-Opener-Policy header is missing.	Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Resource-Policy	Cross-Origin-Resource-Policy header is missing.	Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Embedder-Policy	Cross-Origin-Embedder-Policy header is missing.	Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
LOW	X-Permitted-Cross-Domain-Policies	X-Permitted-Cross-Domain-Policies header is missing.	Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

5. Successful Security Checks

Check	Severity	Details
TLS Version	INFO	Secure TLS version detected: TLSv1.3
SSL Certificate	INFO	Valid TLS certificate was successfully retrieved.
TLS Cipher	INFO	Negotiated cipher: TLS_AES_256_GCM_SHA384
Certificate Hostname Match	INFO	Certificate hostname matches the requested domain (SAN/CN verified).
Legacy Protocol Support - TLSv1.0	INFO	Server correctly rejects TLSv1.0.
Legacy Protocol Support - TLSv1.1	INFO	Server correctly rejects TLSv1.1.
Protocol Support - TLSv1.2	INFO	Server supports TLSv1.2.
Protocol Support - TLSv1.3	INFO	Server supports TLSv1.3.
HSTS	INFO	Header present: max-age=31536000; includeSubDomains; preload
Content Security Policy	INFO	Header present: frame-ancestors 'self' https://growlity.com
X-Content-Type-Options	INFO	Header present: nosniff
Referrer Policy	INFO	Header present: same-origin, strict-origin-when-cross-origin
Permissions Policy	INFO	Header present: camera=(self), microphone=(self), geolocation=(self), payment=(self), usb=(), interest-cohort=()
CSP Strength	INFO	CSP does not use unsafe-inline, unsafe-eval, or an obvious wildcard source.
HSTS Strength	INFO	HSTS configured with sufficient max-age, includeSubDomains and preload.
Clickjacking Protection	INFO	Framing is restricted via X-Frame-Options and/or CSP frame-ancestors.
CORS Configuration	INFO	No permissive CORS wildcard detected.
Cookie Security	INFO	No cookies were set during the initial response.
HTTP Methods	INFO	No explicit Allow header exposing methods.
Sensitive Path Exposure	INFO	No tested sensitive paths returned HTTP 200.
Mixed Content	INFO	No obvious HTTP resource references detected.
Cache-Control	INFO	Cache-Control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Subresource Integrity (SRI)	INFO	No external scripts missing SRI (or none detected).
Robots.txt	INFO	No robots.txt found (nothing to disclose).
HTTP Protocol Version	INFO	Negotiated protocol (via requests/urllib3): HTTP/1.1. Server advertises Alt-Svc: h3=":443"; ma=86400 (h3/h2 support).
DNS - Name Servers	INFO	NS records: colette.ns.cloudflare.com., kolton.ns.cloudflare.com.
DNS - SPF Record	INFO	SPF record found in TXT records.
DNSSEC	INFO	DNSSEC is enabled for this domain.
Domain Expiry (WHOIS)	INFO	Domain registered until 2028-05-26 08:15:37+00:00 (633 days remaining).
Certificate Transparency Logs	INFO	Could not retrieve CT log data (crt.sh unavailable or rate-limited).
Version Disclosure	INFO	No specific software version numbers were disclosed in response headers.
HTTP TRACE Method	INFO	Server does not permit TRACE requests (HTTP 405).
Directory Listing	INFO	No directory listing detected on commonly probed paths.
Open Redirect	INFO	No open redirect behavior detected on commonly probed parameters.
Password Field Autocomplete	INFO	No password input fields detected on this page.
Exposed Secrets in Page Source	INFO	No obvious credential/key patterns detected in page source.
Cryptomining / Known Malicious Script Source	INFO	No script tags referencing known malicious/cryptomining domains were found.
Obfuscated Script / Hidden Iframe Patterns	INFO	No obfuscated script or hidden-iframe patterns detected in page source.
Unsolicited Cross-Domain Redirect	INFO	No meta-refresh redirect detected.
Self Signed Certificate	INFO	Certificate is not self-signed.

Check	Severity	Details
Certificate Expiry	INFO	Certificate has 45 days remaining.

6. Sensitive Path Enumeration

Path	HTTP Status	Risk	Exposed
.env	403	INFO	NO
.git/config	403	INFO	NO
config.json	403	INFO	NO
config.php	403	INFO	NO
debug	403	INFO	NO
actuator	403	INFO	NO
phpinfo.php	403	INFO	NO
server-status	403	INFO	NO
backup.zip	403	INFO	NO
backup.sql	403	INFO	NO
.DS_Store	403	INFO	NO
composer.json	403	INFO	NO
package-lock.json	403	INFO	NO
webpack.config.js	403	INFO	NO
docker-compose.yml	403	INFO	NO
database.sql	403	INFO	NO
dump.sql	403	INFO	NO
admin	403	INFO	NO
admin/	403	INFO	NO
debug.log	403	INFO	NO
error.log	403	INFO	NO
swagger.json	403	INFO	NO
swagger-ui.html	403	INFO	NO
graphql	403	INFO	NO
.htaccess	403	INFO	NO
wp-config.php	403	INFO	NO
.well-known/security.txt	403	INFO	NO
.git/HEAD	403	INFO	NO
.env.local	403	INFO	NO
.env.production	403	INFO	NO
.env.backup	403	INFO	NO
credentials.json	403	INFO	NO
secrets.yml	403	INFO	NO
secrets.yaml	403	INFO	NO
.aws/credentials	403	INFO	NO
id_rsa	403	INFO	NO
id_rsa.pub	403	INFO	NO
.npmrc	403	INFO	NO
.idea/workspace.xml	403	INFO	NO
.vscode/settings.json	403	INFO	NO
web.config	403	INFO	NO
vendor/composer/installed.json	403	INFO	NO
storage/logs/laravel.log	403	INFO	NO

Path	HTTP Status	Risk	Exposed
wp-content/debug.log	403	INFO	NO
.well-known/openid-configuration	403	INFO	NO
server.key	403	INFO	NO
server.pem	403	INFO	NO

7. Cookie Security

No cookies were observed during this scan - the initial response did not include any **Set-Cookie** headers, so there is nothing to assess here.

8. Prioritized Recommendations

1. Verify website availability and server configuration.
2. Configure a proper X-Frame-Options header.
3. Remove unnecessary technology/version information from HTTP headers.
4. Configure a permanent HTTP to HTTPS redirect.
5. Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
6. Add a CAA record restricting which Certificate Authorities may issue certificates.
7. Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
8. Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
9. Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
10. Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

9. AI Overall Review & Suggestions

<think>

Thinking Process:

1. **Deconstruct the Input:**

* Target: `https://growlity.com/blog/brsr-principles-guide-india`

* Score: 80% (This is interesting. Usually, a CRITICAL risk implies a lower score, but the score is 80%. This might be a weighted score where the critical issue is weighted heavily but other checks passed, or the scoring algorithm is specific. I should mention the score but emphasize the CRITICAL status.)

* Risk Status: CRITICAL_RISK.

* Checks: 51 total, 41 passed, 10 failed.

* Breakdown: Critical: 1, High: 1, Medium: 2, Low: 6.

* Failing Checks:

* CRITICAL: Website Availability (HTTP 403).

* HIGH: HTTP to HTTPS Redirect (HTTP doesn't redirect to HTTPS).

* MEDIUM: X-Frame-Options missing.

* MEDIUM: DNS CAA Record missing.

* LOW: Server info exposed (Cloudflare).

* LOW: No security.txt.

* LOW: COOP missing.

* LOW: CORP missing.

* LOW: COEP missing.

* LOW: X-Permitted-Cross-Domain-Policies missing.

2. **Drafting - Section by Section (Mental Outline & Plain Language Translation):**

* **Overall Security Posture:**

* Score is 80%, which sounds okay, but the status is CRITICAL. This is a contradiction that needs explaining. The 80% likely reflects the number of checks passed ($41/51 \approx 80\%$), but the *quality* of the failures is severe.

* Key point: The site is returning a 403 Forbidden error. This means the site is effectively down or blocked for the scanner. This is the biggest issue.

* Plain language: The website has a decent number of security checks passing, resulting in an 80% score, but this is misleading because the site is currently inaccessible due to a critical error. The security posture is compromised primarily by availability issues rather than just configuration gaps.

* **Business-Critical Risks:**

* Risk 1: HTTP 403. Why it matters: Users can't access the site. Revenue loss, reputation damage, SEO impact. If the scanner gets a 403, real users might too, or it's a WAF misconfiguration.

* Risk 2: HTTP to HTTPS Redirect. Why it matters: Users typing `http://` might get stuck on insecure HTTP, risking data interception, or get an error. It's a basic hygiene issue.

* Risk 3: X-Frame-Options. Why it matters: Clickjacking. Users could be tricked into clicking hidden elements.

* **Synthesis:** The 403 is the showstopper. The redirect is a high risk for data security. X-Frame is a medium risk for user interaction security.

* Plain language: The most urgent issue is the 403 error, which blocks access and stops business operations. Next is the lack of HTTP-to-HTTPS redirect, which leaves user data vulnerable to interception if they start on an insecure connection. Missing clickjacking protection also poses a risk to user trust and account safety.

* *Prioritized Remediation Order:*

* Order: Critical -> High -> Medium -> Low.

* 1. Fix 403. Check WAF rules, IP blocks, or server config.

* 2. Fix HTTP->HTTPS redirect. Ensure Cloudflare or origin server forces HTTPS.

* 3. Add X-Frame-Options.

* 4. Add CAA record.

* 5. Low stuff (Headers, security.txt, server header).

* Plain language: First, resolve the 403 Forbidden error immediately to restore access. Second, configure the HTTP to HTTPS redirect to ensure all traffic is encrypted. Third, add the X-Frame-Options header to prevent clickjacking. Fourth, implement a CAA DNS record. Finally, address the remaining low-severity header and disclosure issues.

* *Quick Wins:*

* What's low effort/high impact?

* X-Frame-Options is usually one header line. High impact (prevents clickjacking), low effort.

* CAA record is one DNS entry. Low effort, good practice.

* security.txt is just a file upload. Low effort, shows responsibility.

* Server header: Cloudflare usually hides this, but if exposed, might be a config tweak.

* *Synthesis: Adding X-Frame-Options is a quick win. Adding CAA is a quick win.

* Plain language: Adding the X-Frame-Options header is a quick configuration change that immediately mitigates clickjacking risks. Setting a CAA record in DNS is also a simple step that restricts certificate issuance. Uploading a security.txt file requires minimal effort but demonstrates a commitment to responsible disclosure.

3. **Review and Refine (Self-Correction/Simulation):**

* *Critique: Did I use markdown headers? *Check: No.

* *Critique: Did I use bullet symbols other than plain text? *Check: The prompt asks for "no bullet symbols other than plain text". This usually means I can use dashes or asterisks if they are plain text, or just write paragraphs. The prompt says "no bullet symbols other than plain text", which is slightly ambiguous. It likely means "don't use markdown bullets like ` ` or ` ` that render as bullets, use plain text formatting". Or it might mean "use plain text bullets". Given the constraint "no markdown headers", I should avoid `#` or `##`. I should write in paragraphs. The output should be text blocks.

* *Refinement on "no bullet symbols other than plain text": This likely means the output should not contain markdown syntax for bullets. I can use dashes in the text if needed, but better to write flowing paragraphs or use plain text indicators like "First," "Second,". I'll write in concise paragraphs to be safe.

* *Critique: Did I cover all 4 points?

* 1. Posture: Yes. 80% score vs Critical risk explained.

* 2. Business risks: Yes. 403, Redirect, X-Frame.

* 3. Prioritization: Yes. 403 -> Redirect -> X-Frame -> CAA -> Others.

* 4. Quick wins: Yes. X-Frame, CAA, security.txt.

* *Critique: Is it concise? *Check: Yes, a few short paragraphs.

* *Critique: Plain language? *Check: Avoided jargon where possible, explained 403, HTTPS, Clickjacking.

* *Specific Detail Check:* The target is a blog post. The 403 might be specific to that URL or the whole site. The check says "Website returned HTTP 403". I should mention this affects availability. The server is Cloudflare. The 403 is likely a Cloudflare WAF rule or firewall rule blocking the scanner IP, or a geo-block, or the site is down. I should mention checking WAF/Firewall rules.

* *Refinement on 403:* Since it's Cloudflare, the 403 is almost certainly a WAF rule, Firewall rule, or Access policy. I'll mention checking Cloudflare settings.

* *Refinement on Redirect:* Cloudflare has a "Always Use HTTPS" toggle. This is a very quick fix if enabled. I should mention this as a quick win or part of the fix.

* *Refinement on Score:* 80% with Critical risk is a red flag for the client. They might think 80% is good. I need to emphasize that the score is inflated by the volume of passed checks but the critical failure negates the value.

4. **Final Polish (Mental Draft of Response):**

The website currently shows an 80% security score, but this metric is misleading because the audit was flagged as CRITICAL_RISK due to a fundamental availability failure. While 41 out of 51 checks passed, the site is returning an HTTP 403 Forbidden error, meaning it is effectively blocked or inaccessible to the scanner and potentially to real users. This availability issue overshadows the configuration gaps, indicating that immediate attention is required to restore access before other security improvements can be validated or utilized.

The most business-critical risk is the HTTP 403 error, which halts all user access, damages reputation, and impacts search engine rankings. This is likely caused by a misconfigured firewall rule or WAF policy on Cloudflare. The second major risk is the missing HTTP to HTTPS redirect, which leaves user data vulnerable to interception if visitors access the site via an insecure connection. Additionally, the absence of the X-Frame-Options header exposes the site to clickjacking attacks, where malicious actors could trick users into performing unintended actions.

Remediation should begin immediately by investigating and resolving the HTTP

Generated by TestPilot-AI Security Audit - automated scan results should be validated by a qualified security professional before remediation sign-off.